

Resumo executivo

A Zurich quer **conter o “day after”** no SharePoint: o que foi concedido hoje e **não deveria** continuar amanhã, sobretudo após **movimentações internas**. O **MVP (Fase 1)** do **produto SaaS da Foursys** entrega exatamente isso, em **modo batch**:

- **Coleta** eventos do **Unified Audit Log** do Microsoft 365 para o SharePoint (ex.: compartilhamentos, concessões e acessos relevantes).
- **Confronta** esses eventos com uma **Base Autoritativa** de **regras determinísticas** (perfil/área × repositório).
- **Classifica violações** e **notifica por e-mail** a Segurança com **relatório diário** (podendo aumentar a frequência para 3–6 execuções/dia).
- **Sem real-time e sem IA** agora; **auto-remediação** e **educação do usuário** ficam no **roadmap de produto**, após o “cartão passado”.

Modelo de negócio: SaaS (produto Foursys) com **licença base** (mensal/anual) + **consumo** (escala de logs/regras). **Hospedagem SaaS Foursys**.

2) Escopo do MVP (o que entra / o que não entra)

Entra agora

- Scanner **batch** (1×/dia → até 3–6×/dia).
- **Importador** (CSV/Excel) da Base Autoritativa no **formato Foursys** + **CRUD** de regras no Portal.
- **Relatório diário** (CSV/HTML) e **e-mail** à Segurança com **ID da regra violada**, severidade e evidências mínimas.

Fica fora (roadmap)

- Notificação ao usuário, **auto-remediação** via Graph, **real-time** por notificações de mudança e **detecção por IA/anomalias** (UEBA/ML). Para futuramente adotar **notificações de mudança do Microsoft Graph** (webhooks/Event Hubs/Event Grid) quando a Zurich exigir latência menor.

3) Pontos acordados

- **Produto, não projeto sob medida:** função de **produto multitenant** com **billing por tenant** é requisito interno da Foursys (para vender a outros clientes).
- **Base Autoritativa:** a Zurich **monta a 1ª versão**; a plataforma **importa** e depois **mantém** via front-end.
- **Determinístico, sem LLM/IA** no MVP.
- **Proteção de IP** (quando BYOC): opções de **obfuscação, binários compilados (.NET)** e/ou **containers** com conteúdo protegido.

4) Premissas

1. **Auditoria unificada (M365)** está habilitada e acessível (por API/connector), com retenção adequada às necessidades do cliente (E3/E5 influenciam retenção).
2. **Metadados** (sites/drives/usuários) obtidos via **Microsoft Graph**.
3. **Batch** como modo de operação inicial; **sem bloqueio automático**.
4. **LGPD:** minimização de PII em relatórios (usar UPN/ID), dados preferencialmente no Brasil, evidências exportáveis.
5. **Hospedagem:** **SaaS Foursys** ou **BYOC Zurich**, sempre com **Infra-as-Code**.

5) Requisitos do MVP

5.1 Funcionais

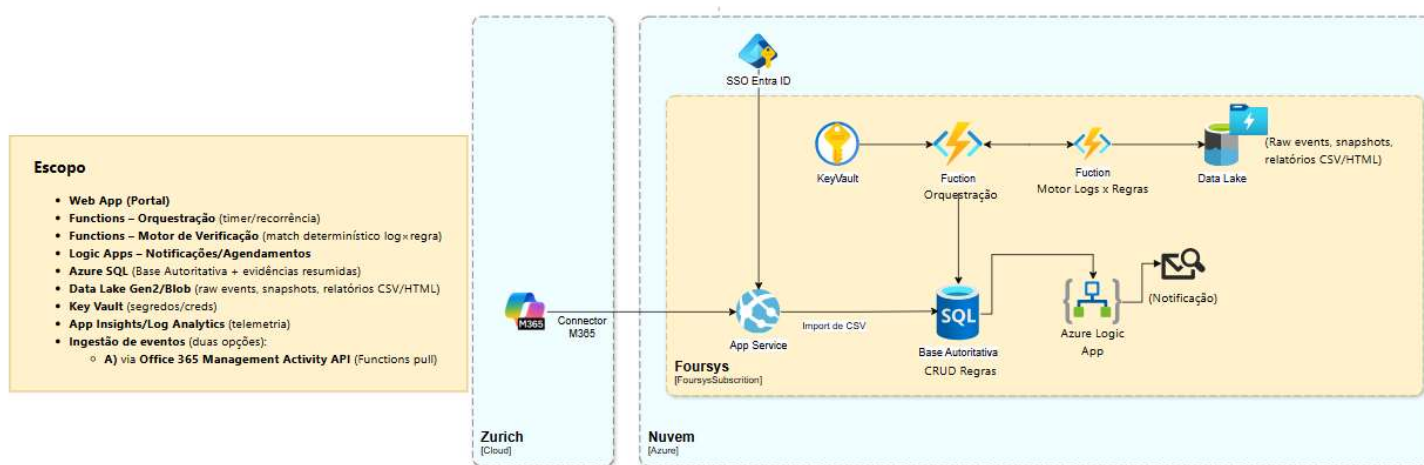
- **Ingestão** dos eventos do SharePoint a partir do **Unified Audit Log** do Microsoft 365 (ex.: Audit.SharePoint, Audit.General, DLP).
- **Leitura de metadados** (sites, bibliotecas/drives, usuários/pertencimento) via **Microsoft Graph** (uso de `select/expand` para eficiência).
- **Base Autoritativa (modelo Foursys) + importador CSV/Excel + CRUD** de regras.
- **Motor de verificação** (match determinístico **log x regra**) com paralelismo por site/coleção.
- **Relatório diário** (CSV/HTML) + **e-mail** (Segurança), com **ID/descrição da regra violada**, severidade e evidências mínimas.
- **Portal** para consulta, filtros e download de relatórios.

5.2 Não-funcionais

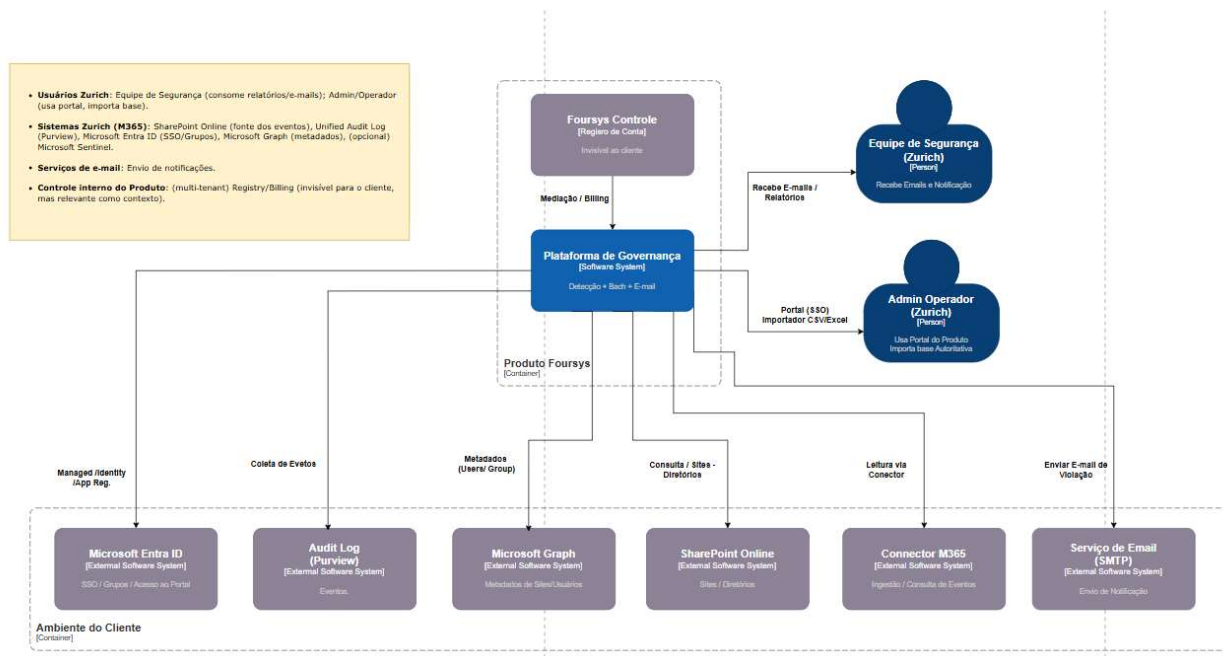
- **Segurança:** **Key Vault, Managed Identity** (para Graph/APIs), RBAC; MFA/Conditional Access para admins.
- **Observabilidade:** **Application Insights / Log Analytics** (telemetria, falhas, SLAs).
- **Escala:** 1×/dia (início) → 3–6×/dia; janelas de execução; limites por rodada.
- **Auditabilidade:** trilha de coleta/avaliação e retenção exigida.

Multitenancy: **tagging por tenant, isolamento de dados (DB por tenant ou schema por tenant)** e métricas para billing.

6) Arquitetura de Solução (MVP)



7) C4 Contexto



8) Serviços Azure — inventário para estimativa

- **Azure Functions (Consumption)** — orquestração e motor de verificação.
- **Azure Logic Apps (Consumption)** — agendamento/recorrência e **e-mail**.
- **Azure Storage (Data Lake Gen2)** — landing de eventos + relatórios.
- **Azure SQL Database** — Base Autoritativa e evidências resumidas.
- **Azure App Service (Web App)** — Portal e CRUD.
- **Azure Key Vault** — segredos/creds.
- **Application Insights / Log Analytics** — telemetria.